

TASK-3: WEB APPLICATION SECURITY REPORT

1. Introduction

Web Application Security focuses on protecting web applications from security threats and vulnerabilities that attackers may exploit. Modern web applications handle sensitive user data such as login credentials, personal details, and financial information, making them a prime target for cyberattacks.

This task aims to identify and understand common web application vulnerabilities listed in the OWASP Top 10 using a controlled lab environment. The testing was conducted using Damn Vulnerable Web Application (DVWA) installed on Kali Linux

2. Objective of the Task

The objectives of this task are:

To identify common web application vulnerabilities

To exploit these vulnerabilities in a safe environment

To understand how attackers misuse security flaws

To learn mitigation techniques to secure applications

3. Tools & Environment Used

Operating System: Kali Linux

Vulnerable Application: Damn Vulnerable Web Application (DVWA)

Web Server: Apache

Database: MySQL

Security Testing Tool: Burp Suite

Online Tool: securityheaders.com

4. Vulnerabilities Identified and Explained

4.1 SQL Injection (SQLi)

Description

SQL Injection is a vulnerability where an attacker injects malicious SQL queries into input fields, allowing unauthorized access to the database.

Impact

Disclosure of usernames and passwords

Database manipulation

Authentication bypass

Attack Demonstration

An SQL injection payload was entered into a vulnerable input field, which resulted in the extraction of all user records from the database.

Mitigation

Use prepared statements

Use parameterized queries

Validate and sanitize user inputs

Avoid displaying database errors

4.2 Cross-Site Scripting (XSS)

Description

Cross-Site Scripting occurs when an attacker injects malicious JavaScript code into a web application, which executes in the victim's browser.

Types of XSS Tested

Stored XSS: Malicious script stored permanently in the database

Reflected XSS: Script reflected through URL or input fields

Impact

Session hijacking

Cookie theft

Defacement of web pages

Mitigation

Input validation

Output encoding

Content Security Policy (CSP)

Disable inline JavaScript execution

4.3 Cross-Site Request Forgery (CSRF)

Description

CSRF forces an authenticated user to perform unwanted actions without their knowledge by exploiting trust between the user and the web application.

Impact

Unauthorized password change

Account takeover

Data manipulation

Attack Demonstration

A password change request was executed without verifying the user's identity.

Mitigation

Implement CSRF tokens

Use SameSite cookies

Re-authentication for sensitive actions

4.4 File Inclusion Vulnerabilities

Types

Local File Inclusion (LFI): Accessing local files on the server

Remote File Inclusion (RFI): Executing remote malicious files

Impact

Sensitive file disclosure

Server compromise

Remote code execution

Mitigation

Avoid dynamic file inclusion

Whitelist allowed files

Disable URL inclusion

Use secure file handling functions

4.5 Burp Suite – Advanced Web Testing

Description

Burp Suite is a web vulnerability scanner and proxy tool used to intercept and modify HTTP requests.

Attack Demonstration

Login requests were intercepted and sent to Burp Intruder to perform fuzzing and brute-force testing.

Impact

Weak authentication exploitation

Credential guessing

Session manipulation

Mitigation

Implement account lockout mechanisms

Use strong password policies

Enable CAPTCHA

Use HTTPS encryption

4.6 Web Security Headers

Description

Security headers provide additional protection against attacks like XSS, clickjacking, and data injection.

Common Headers

Content-Security-Policy

X-Frame-Options

X-XSS-Protection

Strict-Transport-Security

Analysis Tool Used

securityheaders.com

Mitigation

Configure proper HTTP security headers

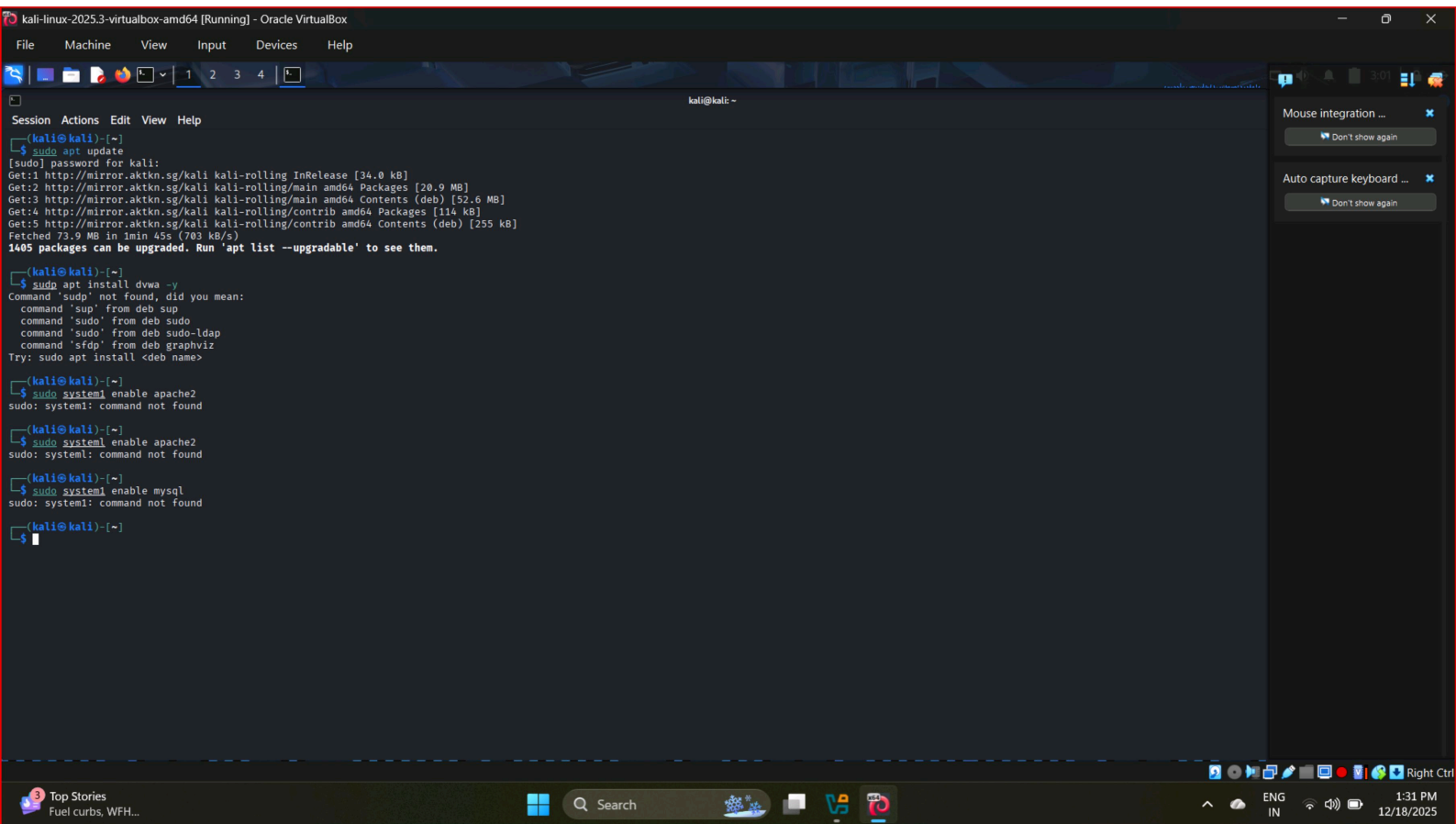
Enforce HTTPS

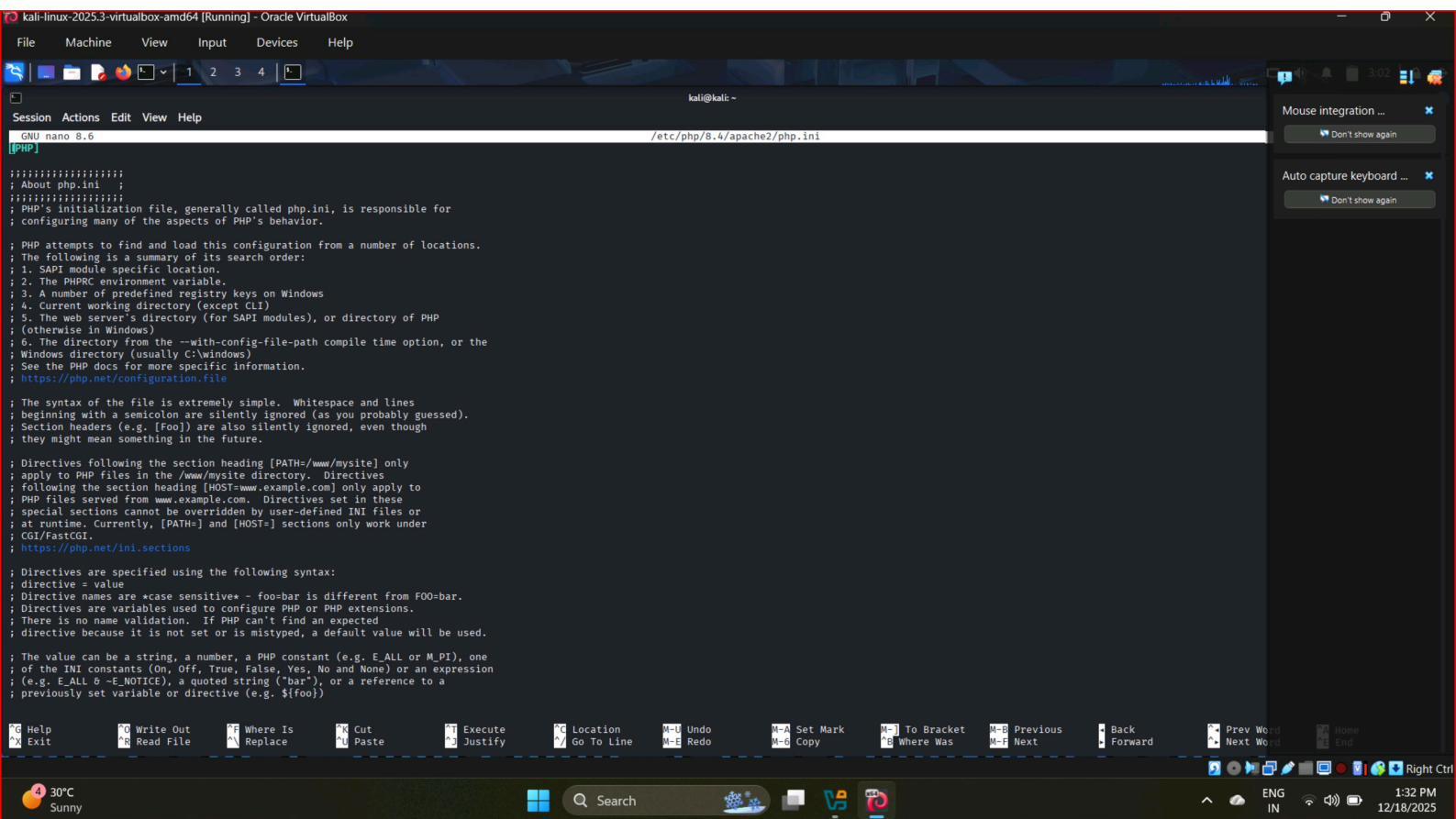
Regular security audits

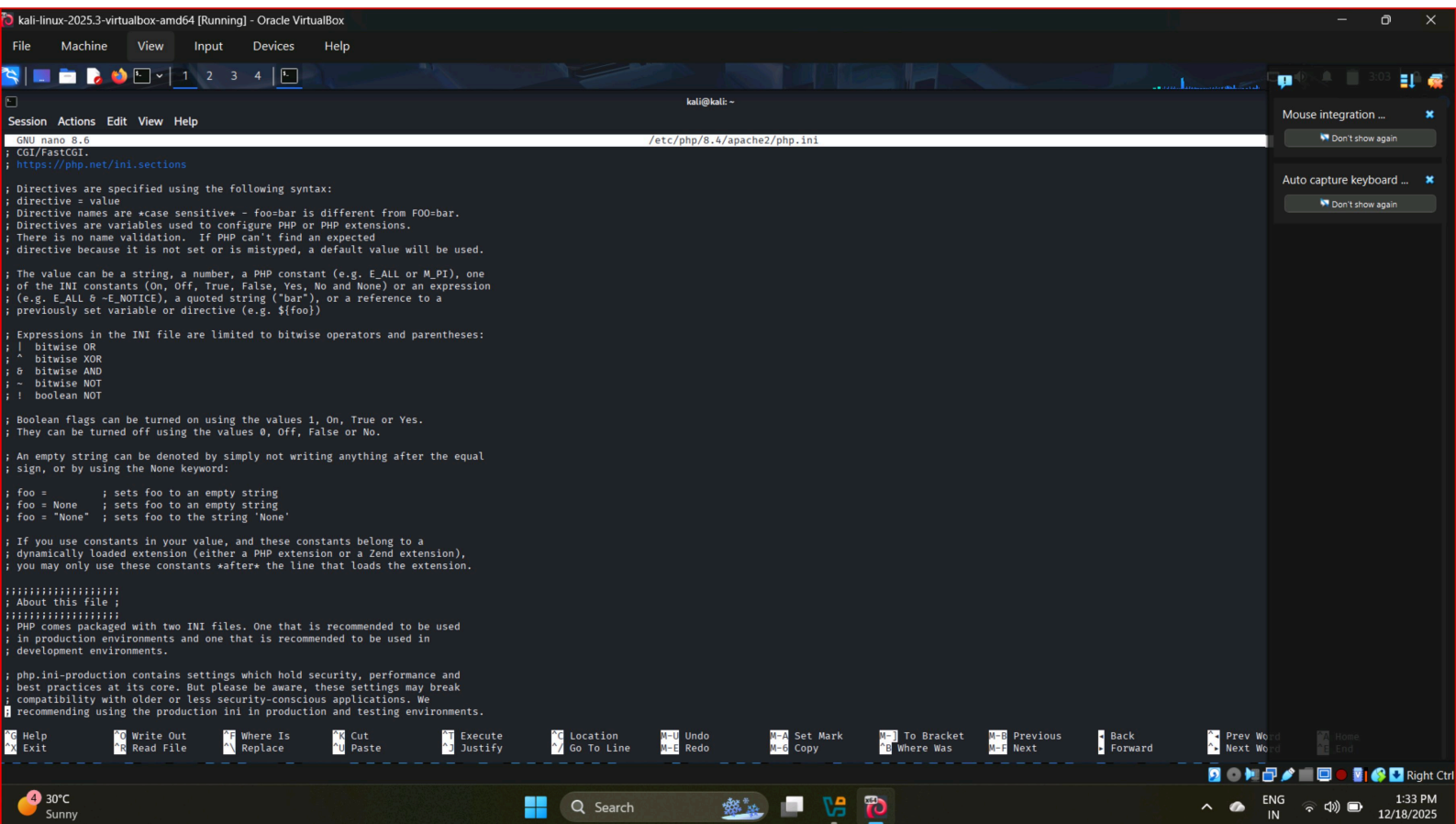
5. Conclusion

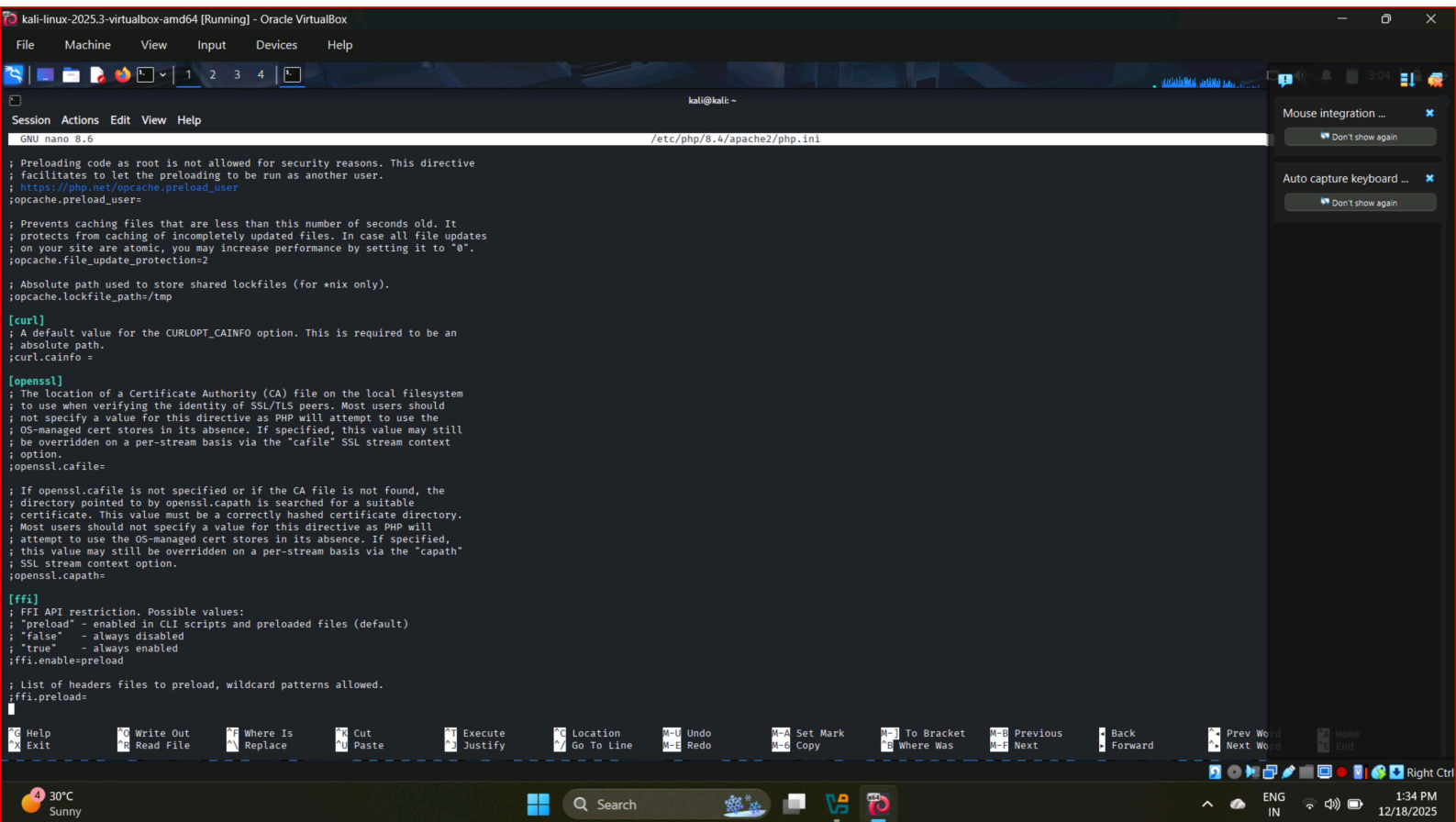
This task provided practical exposure to real-world web application vulnerabilities. By exploiting OWASP Top 10 vulnerabilities in a controlled environment, a better understanding of how attackers operate was gained. Learning mitigation techniques helps in building secure and resilient web applications.

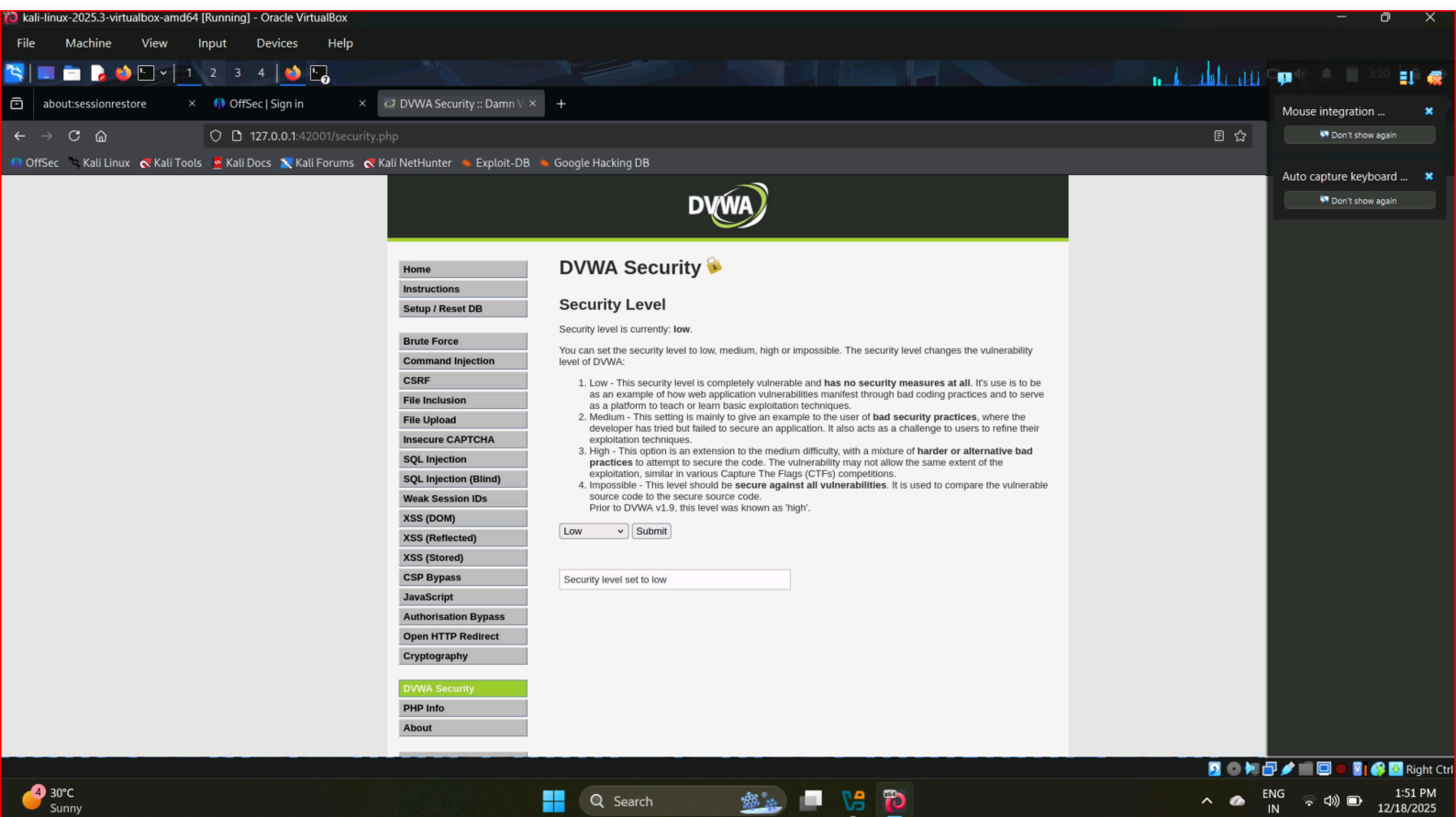
Web security testing is a critical aspect of cybersecurity, and regular vulnerability assessments can significantly reduce the risk of cyberattacks.

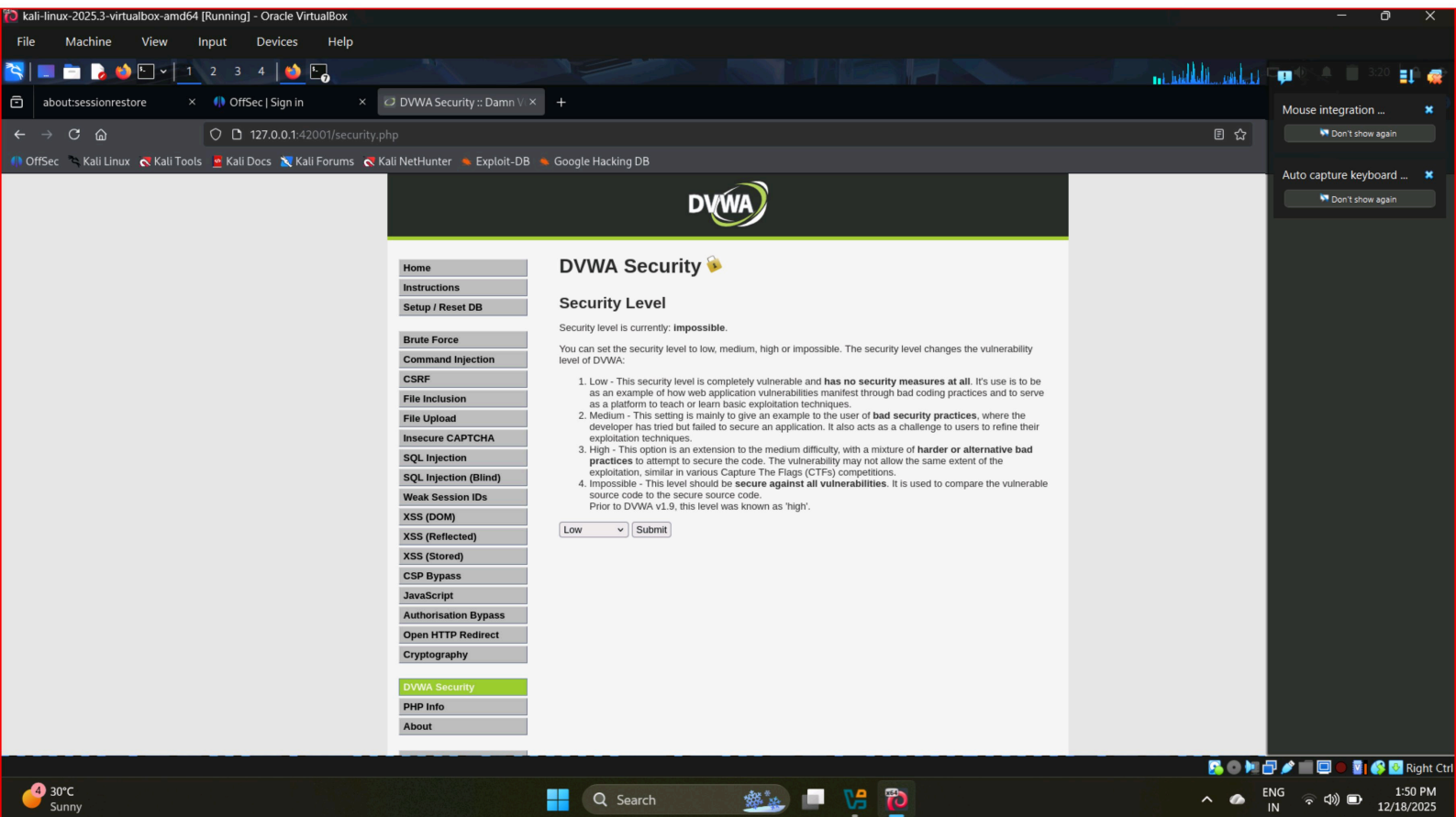


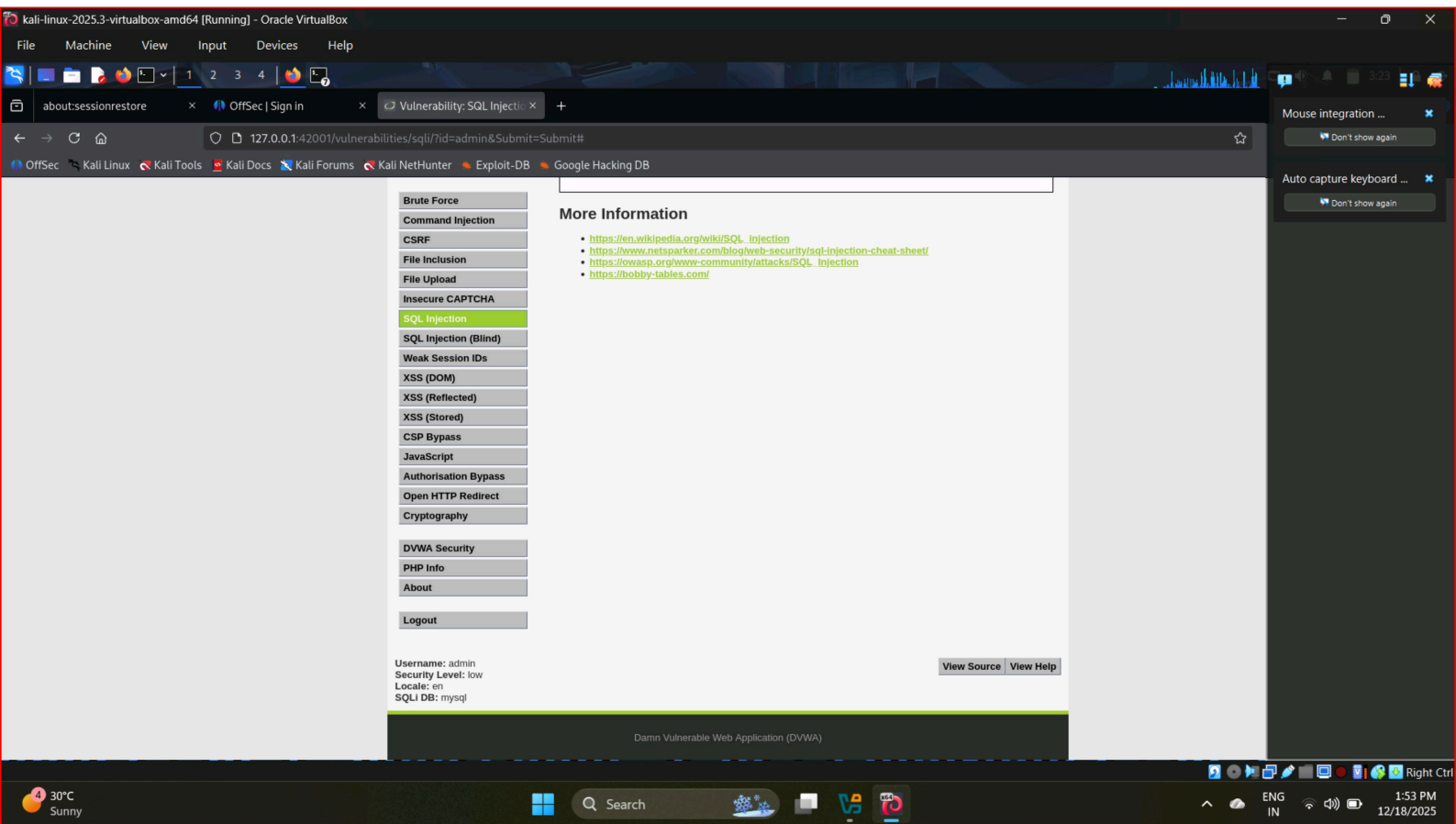


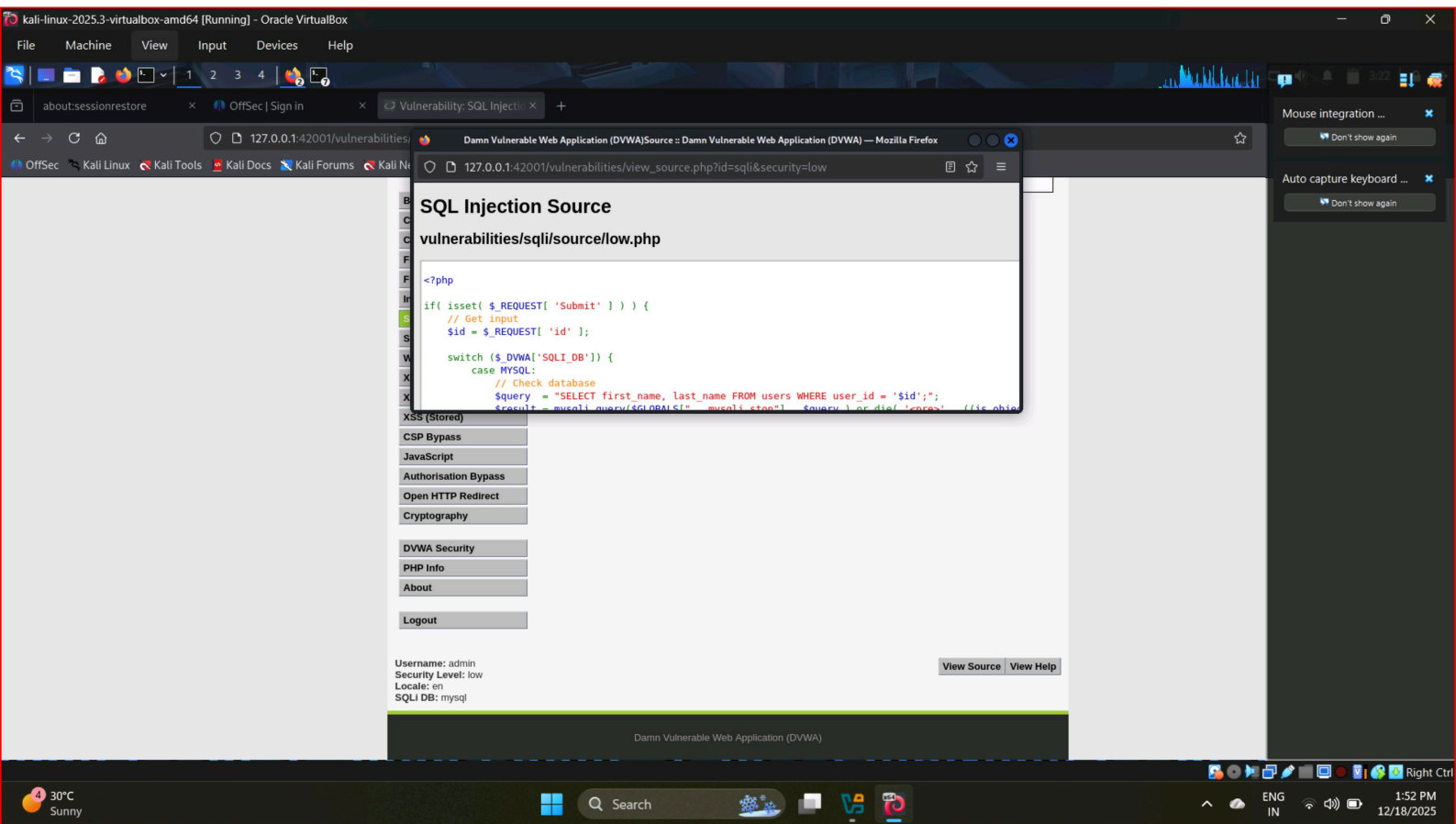


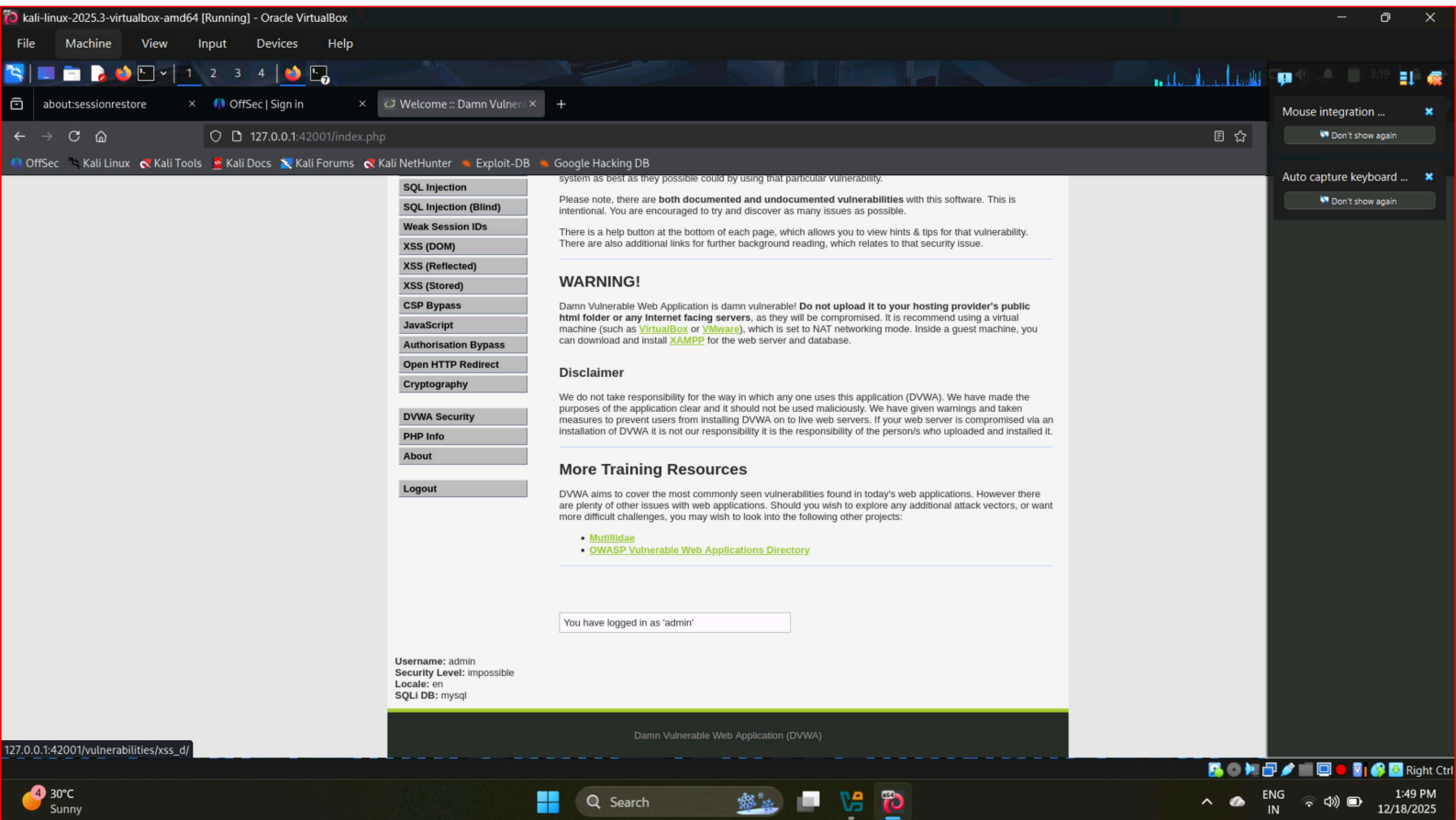












kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox

FileMachineViewInputDevicesHelp

about:sessionrestore

Setup :: Damn Vulnerable: x

+

127.0.0.1:42001/setup.php

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

DVWA

Setup DVWAInstructionsAbout

Database Setup

Click on the 'Create / Reset Database' button below to create or reset your database.
If you get an error make sure you have the correct user credentials in: `etc/dvwa/config/config.inc.php`

If the database already exists, **it will be cleared and the data will be reset.**
You can also use this to reset the administrator credentials ("**admin**" // **password**") at any stage.

Setup Check

Web Server SERVER_NAME:

Operating system: `*nix`

PHP version: **8.4.11**
PHP function display_errors: **Disabled**
PHP function display_startup_errors: **Disabled**
PHP function allow_url_include: **Disabled**
PHP function allow_url_fopen: **Enabled**
PHP module gd: **Installed**
PHP module mysql: **Installed**
PHP module pdo_mysql: **Installed**

Backend database: **MySQL/MariaDB**
Database username: **dvwa**
Database password: *********
Database database: **dvwa**
Database host: **127.0.0.1**
Database port: **3306**

reCAPTCHA key: **Missing**

Writable folder `/var/lib/dvwa/uploads/`: **Yes**
Writable folder `etc/dvwa/config/`: **Yes**

Status in red, indicate there will be an issue when trying to complete some modules.

If you see disabled on either `allow_url_fopen` or `allow_url_include`, set the following in your `php.ini` file and restart Apache.

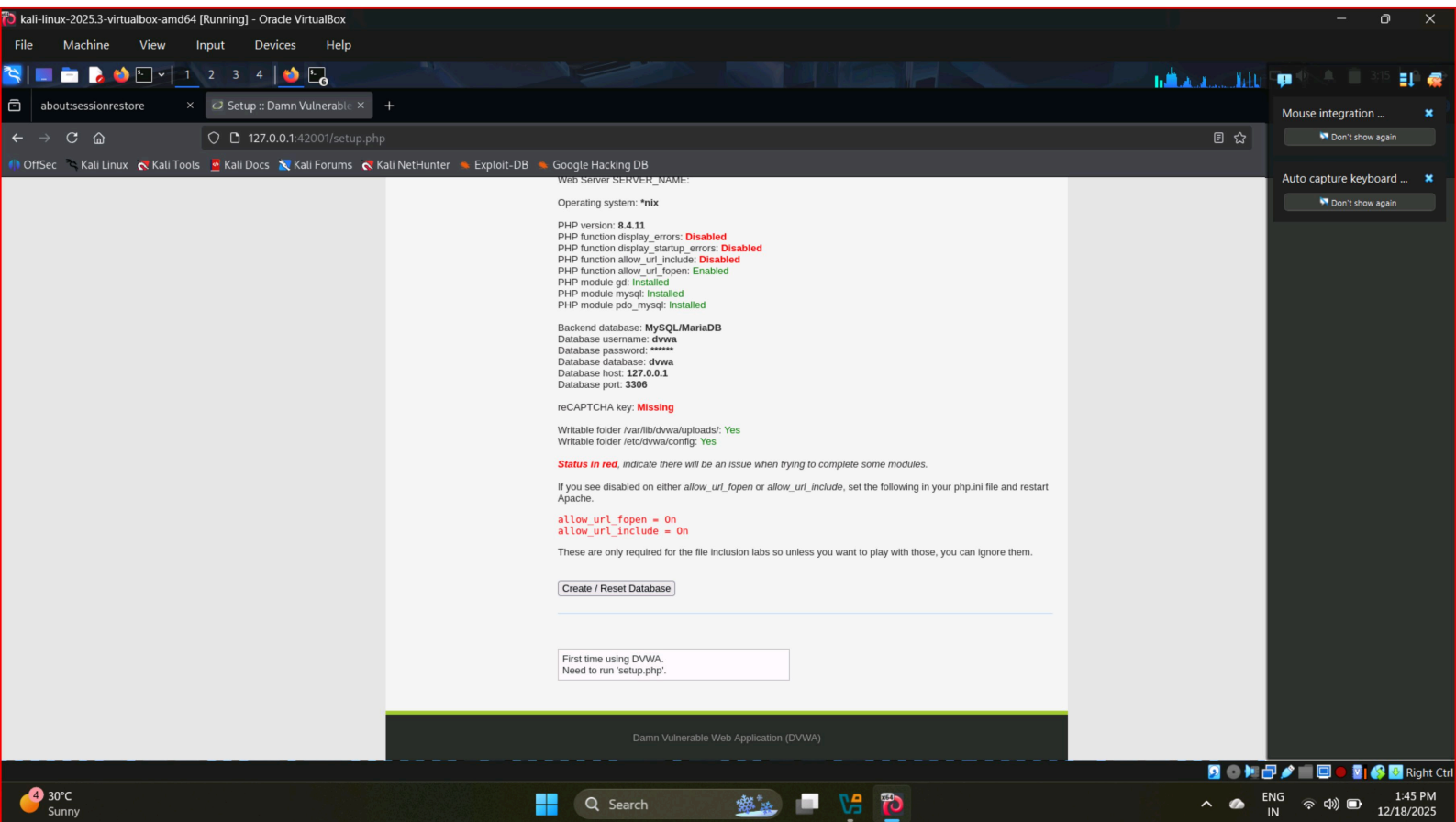
`allow_url_fopen = On`
`allow_url_include = On`

430°C
Sunny

Search

ENG
IN

1:45 PM
12/18/2025



kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox

FileMachineViewInputDevicesHelp

about:sessionrestore

OffSec | Sign in

Welcome :: Damn Vulnerable

127.0.0.1:42001/index.php

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

Authorisation Bypass

Open HTTP Redirect

Cryptography

DVWA Security

PHP Info

About

DVWA

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with various levels of difficulty, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [Vmware](#)), which is set to NAT networking mode. Inside a guest machine, you can download and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

More Training Resources

Mouse integration ...

Don't show again

Auto capture keyboard ...

Don't show again

430°C
Sunny

Search

ENG
IN

1:49 PM
12/18/2025